

ADENTAN MUNICIPAL EDUCATION OFFICE

GovPay Desk

Individual contribution

Clement Danso Boateng

Student ID 22424582

CSIT622 Capstone Project · Group 7

University of Ghana · Department of Computer Science

Clement Danso Boateng: Authorization, policies and security testing

I own authorization: the policies deciding who may do what, and the test suite that tries to break them.

The suite is written from the attacker's side. Each test signs in as one user and attempts something it should not be allowed (reading another department's voucher, promoting itself to administrator, deleting a paid record) and asserts that the attempt fails. Writing those tests before the policies existed showed how much authority was being decided in the browser, where a user can simply ignore it.

Every control now resolves to a policy method on the server. The interface reads the same policies through Inertia's shared props, so what a user sees and what the server permits come from one source and cannot drift apart.

The code this covers

- `app/Policies/`
- `app/Http/Middleware/EnsureUserIsActive.php`
- `tests/Feature/SecurityTest.php`
- `tests/Feature/PermissionVisibilityTest.php`

Questions to be ready for

The examiner may ask about any part of the system, not only this one. These are the ones closest to the work described above:

- Pick any policy and explain what it permits, to whom, and why.
- Why is hiding a button not access control?
- How does deactivating a user take effect on someone already signed in?

Before submitting, confirm this describes what you actually did. This section is assessed individually, and you may be asked to demonstrate any claim in it. Rewrite anything that does not match your own work, and add what is missing, particularly what you found difficult and what you would do differently now.